

Nom : WIDAMOU YANDA

NIVEAU : MASTER 2

FILIERE : SISD

EXERCICE VII : CHAPITRE 7

Ex. 7.1 Analyse Mémoire

L'analyse de la RAM permet de capturer l'état "vivant" du système au moment de l'attaque.

- **(a) Liste des processus** : Utilisation du plugin `windows.pslist`. On cherche des processus anormaux (ex: `nc.exe`, `powershell.exe` avec des arguments encodés en Base64).
- **(b) Connexions réseau** : Utilisation de `windows.netscan`. On identifie une connexion ESTABLISHED depuis l'IP locale vers `203.0.113.42` sur le port `4444`, confirmant un Reverse Shell actif.
- **(c) Malfind** : Le plugin `windows.malfind` permet de repérer les injections de code. On documente les zones de mémoire marquées `PAGE_EXECUTE_READWRITE` (protection RWX) qui contiennent souvent du shellcode ou des DLL injectées.
- **(d) Processus cachés (DKOM)** : On compare les sorties de `pslist` (qui suit la liste chaînée) et `psscan` (qui scanne les structures de données dans la mémoire). Si un processus apparaît dans `psscan` mais pas dans `pslist`, il a été caché via une technique de **Direct Kernel Object Manipulation (DKOM)**, typique d'un rootkit.

Ex. 7.2 Analyse Réseau

L'analyse du trafic réseau permet de reconstituer les étapes de l'exfiltration.

- **(a) IP de Commande & Contrôle (C2)** : L'IP identifiée est **203.0.113.42**. On observe des communications périodiques (beacons).
- **(b) Protocole de communication** : Le trafic semble être du **HTTP/S** (port `443`) pour contourner les pare-feux, ou du **DNS Tunneling** si l'on voit un volume anormal de requêtes TXT vers un domaine spécifique.
- **(c) Données exfiltrées** : Dans Wireshark, en suivant le flux TCP (Follow TCP Stream), on identifie un transfert de fichier volumineux (ex: `Donnees_Client.zip`) via une requête POST ou un transfert SCP/SFTP.
- **(d) Durée de l'activité C2** : En utilisant Zeek (`conn.log`), on calcule la différence entre le premier et le dernier paquet échangé entre le serveur compromis et l'IP C2. Dans ce cas, l'activité a duré **2 heures et 14 minutes**.

Ex. 7.3 CloudTrail

La création d'une clé d'accès (`CreateAccessKey`) depuis une IP TOR est un indicateur de compromission (IoC) critique indiquant une persistance dans le Cloud.

Les 4 actions d'investigation :

1. **Identification de l'identité compromise :** Vérifier quel utilisateur IAM ou quel rôle a été utilisé pour créer cette clé (champ `userIdentity` dans le log CloudTrail).
2. **Audit des actions post-création :** Rechercher toutes les actions effectuées avec la *nouvelle* `access_key_id` générée à 03:22 UTC.
3. **Recherche d'élévation de privilèges :** Vérifier si des politiques IAM ont été modifiées ou attachées à l'utilisateur (`AttachUserPolicy`, `PutUserPolicy`).
4. **Recherche de persistance ou d'exfiltration S3 :** Vérifier les appels `ListBuckets` ou `GetObject` sur les ressources sensibles de LiZbiZ.

Logs à consulter :

- **AWS CloudTrail :** Pour l'historique complet des appels API.
- **Amazon GuardDuty :** Pour voir les alertes de type `UnauthorizedAccess:IAMUser/TorIPCaller`.
- **VPC Flow Logs :** Pour vérifier si des données ont été transférées vers l'extérieur depuis des instances EC2 associées.
- **S3 Server Access Logs :** Si des fuites de données au niveau des compartiments S3 sont suspectées.

EXERCICE VIII : CHAPITRE 8

Ex. 8.1 Redaction playbook

ETAPE	Action/Décision	Outils	Escalade
Détection	Alerte EDR/SIEM. Vérifier si le processus est légitime	Wazuh, SYSMON	N1 vers N2
Isolation	Couper le reseau des machines infectées. Isoler le segment VLAN	SWITCH (VLAN quarantaine)	Responsable infra
Analyse	Identifier la souche et le vecteur d'entrée (rdp/phishing)	Virus total	Expert Forensique
Eradication	Supprimer les malwares, réinitialiser les mots de passes	EDR, BASH	DSI

Récupération	Restaurer via backups	Cloud backup	DG
Post Mortem	Mise a jous des règles IDS et retour d'experience	Rapport d'incident	Tous les membres

Ex. 8.2 Classification

Alerte : Modification de `/etc/passwd` sur `srv-web-01` par `www-data`.

- **Classification : CRITIQUE / Incident Majeur.**
- **Justification :** L'utilisateur `www-data` (serveur web) ne doit jamais écrire dans `/etc/passwd`. Cela indique une **élévation de privilèges réussie** (Privilege Escalation) suite à une faille RCE (Remote Code Execution). L'attaquant a désormais le contrôle total du système.

5 premières actions à mener :

1. **Isolation Réseau :** Isoler immédiatement `srv-web-01` pour empêcher le mouvement latéral vers l'ERP.
2. **Capture de la RAM :** Collecter la mémoire pour identifier l'exploit utilisé en mémoire.
3. **Audit des processus :** Identifier tous les processus lancés par `www-data` (ex: `reverse shell`).
4. **Vérification de l'intégrité :** Comparer `/etc/passwd` avec une version saine pour identifier les comptes ajoutés.
5. **Revue des logs WAF/Apache :** Trouver l'URL spécifique ayant permis l'injection de commande.

Ex. 8.3 Rapport d'incident

À l'attention de : Monsieur le Directeur Général

Objet : Rapport de situation suite à l'intrusion du 12 avril 2026

1. Nature de l'incident Le 12 avril 2026, entre 02h47 et 04h00, notre infrastructure a subi une cyberattaque ciblée. Un intrus a pénétré via notre serveur web pour s'introduire dans le serveur de gestion (ERP) contenant nos données sensibles.

2. Impact constaté

- **Données :** Environ 50 000 dossiers clients ont été consultés. Une tentative d'effacement des traces informatiques a été détectée sur le serveur comptable.
- **Opérations :** Les services de facturation ont été suspendus pendant 4 heures par mesure de sécurité.
- **Confidentialité :** Risque de fuite de données clients (noms, adresses, contrats).

3. Mesures prises Dès l'alerte, nos équipes ont isolé les serveurs touchés pour stopper la progression de l'attaquant. La faille utilisée a été colmatée et l'accès frauduleux a été supprimé. Une enquête numérique approfondie est en cours pour sécuriser l'ensemble du réseau.

4. Coût estimé et Risques

- **Coûts directs** : Expertise technique et remise en état (env. 5 000 000 FCFA).
- **Risque juridique** : Obligation de notification à l'ANTIC sous 72h conformément à la loi camerounaise 2010/012, sous peine de sanctions.

5. Recommandations stratégiques

- **Renforcement immédiat** : Mise en place d'une double validation (MFA) pour tous les accès administratifs.
- **Modernisation** : Investir dans une solution de détection automatique des menaces (EDR) pour réduire le temps de réaction de 27 minutes à moins de 2 minutes.